סיכום עיבוד המידע: מה המוצר שומר, איפה, ומי מקבל (עברית)

מסמך	סיכום עיבוד המידע: מה המוצר שומר, איפה, ומי מקבל (עברית)
נתיב המקור	docs/privacy/he/01-data-processing-summary.md
גרסת המקור	origin/main @ b6eb212ec
הוכן לחבילה	2026-10-24
מצב	הנוסח המקורי נשמר ללא שינוי; עיצוב בלבד. טיוטה לבדיקת עורך דין, אינו ייעוץ משפטי.

---

01 - סיכום עיבוד נתונים: מה SmplWise Arx שומרת

סטטוס: טיוטה לארגון וליועצו המשפטי. אין זו חוות דעת משפטית ואין בה קביעה על עמידה בדין. העובדות אומתו בקריאת הקוד וההגירות ב-(19.10.2026) `018795f96` @ `origin/integ/290`. הנתיבים יחסיים לשורש המאגר; = `B/` `smplwise_vms/backend/smplwise/`. כל קביעה שדורשת עורך דין מסומנת **REQUIRES COUNSEL REVIEW** (דורש בחינת יועץ משפטי) עם מזהה (C1, C2, ...); הרשימה המלאה ב-`../README.md`. הגרסה האנגלית ב-`../en/` היא המקור לנוסח המדויק.

1. היכן הנתונים

- מקומי אחד SQLite על שרת באתר הלקוח. מסד הנתונים הוא קובץ Home Assistant רצה כתוסף של SmplWise Arx, `smplwise.db`, בתיקיית הנתונים של התוסף (`B/config.py`: `data_dir / "smplwise.db"`; התוסף מעגן לצידו `/data`). קבצים: תמונות תוכניות, תמונות קריאות שירות וקובצי חשבוניות (`<data>/tickets/<מזהה קריאה>/`, `<data>/thumbs`) תמונות ממוזערות של אירועי מצלמה (`B/services/tickets/deletion.py`), וגיבויי פרויקט (`<data>/backups`, `B/services/backup.py`, `B/services/thumbnails.py`).

  בקוד אין תכונה שמעתיקה את המסד לשרת שמפעילה SmplWise. חלקים במוצר מתקשרים עם שירותים חיצוניים (סעיף 5). היכן ממוקם השרת, הדיסק והגיבויים מחוץ לאתר הוא עניין פריסה שהמאגר אינו מראה: **REQUIRES COUNSEL REVIEW (C8)**.

  מי "בעל המאגר / מחזיק / מעבד" לכל קטגוריה (הארגון המפעיל את המבנה, SmplWise כספקית התוכנה, אחרים) היא שאלה משפטית שהמסמך אינו עונה עליה: **REQUIRES COUNSEL REVIEW (C1)**.

2. קטגוריות מידע אישי

"טבלה" = טבלת mig; "SQLite" = קובץ ההגירה ב-`B/migrations/`.

#	קטגוריה	נושאי המידע	שדות שנשמרים (מאומת)	טבלה / mig	מתג
A	חשבונות מפעילים	צוות שנכנס למערכת	מזהה משתמש, שם משתמש, שם תצוגה, מקור, דוא"ל אופציונלי, הערת מנהל, ראשון/אחרון נראה, סימוני השבתה/מחיקה; גיבוב סיסמה (PHC), זמן כניסה וכתובת מוסתרת, סשנים (עוגייה מגובבת, IP מוסתר, מדינה, user agent עד 200 תווים, שם מכשיר), קישורי כניסה ראשונה/איפוס (גיבוב בלבד), passkeys, TOTP, קישור למשתמש Home Assistant	`users`, `auth_local_*`, `auth_webauthn_credentials`, `auth_totp*`, `identity_links`, `remote_access_users`, `remote_sign_ins` / mig 0001, 0096, 0098, 0033, 0035	תמיד
B	יומן ביקורת	מפעילים, ומבצעים מסוג `contact:<id>`	זמן, מזהה ושם משתמש מבצע, פעולה, סוג/מזהה משאב, החלטה, סיבה, מזהה בקשה, פרטים (מזהים וספירות; בקריאות שירות שנמחקו: ללא שמות, טלפונים או תוכן - `B/services/tickets/deletion.py`)	`audit_log` / mig 0001	תמיד

#	קטגוריה	נושאי המידע	שדות שנשמרים (מאומת)	טבלה / mig	מתג
C	מדריך אנשים חיצוניים	ספקים, טכנאים, אנשי קשר, עובדים	שם תצוגה, חברה, טלפון (E.164), אינדקס מפתח של הטלפון, דוא"ל, ערוץ מועדף, שפה, הערות, פעיל, יוצר, שיוך אחרון, זמן ואופן אימות הטלפון, שיוך למחלקות	`ticket_contacts`, `ticket_contact_departments`, `ticket_phone_verifications` / mig 0080, 0084, 0091, 0111	`tickets.enabled`
D	קריאות שירות	פונים, מטפלים, ספקים, מי שמוזכר בטקסט חופשי	כותרת, תיאור, טקסט מקום, מזהה ושם יוצר, מכשיר/מקום, היסטוריית סטטוסים (אירועים עם שם מבצע והערה), תמונות (נתיב, גיבוב, גודל, מעלה), שיבוצים (שם מטפל קפוא), תביעות עלות וחשבוניות, בקשות הצעת מחיר (ספק, קבצים, הודעות), יומן הודעות יוצאות/נכנסות (אינדקס מפתח של שולח, לא המספר), יומן גישה לקישורים (זמן, סוג, מפתח לקוח)	`tickets`, `ticket_events`, `ticket_attachments`, `ticket_assignments`, `ticket_cost_*`, `ticket_rfq*`, `ticket_outbox`, `ticket_inbound`, `ticket_link_access` / mig 0079-0117	`tickets.enabled`
E	גישת טכנאים לדלתות	טכנאים חיצוניים שספק שלח	סעיף 3	`access_*` / mig 0107, 0108, 0112	`access.external_grants` (כבוי)
F	הודעות לאנשים (וואטסאפ ממסך האנשים)	אנשים שמערכת הכניסה מכירה	מזהה הנמען (של מערכת הכניסה), מזהה ושם השולח, מזהה/תווית תבנית, אורך הטקסט (לא הטקסט), תוצאה, גיבוב מפתח של הטלפון, מזהי עמדות; רשימת סירוב; שורות הסכמה בקישור (גרסת הודעה, ללא מספר)	`intercom_messages`, `intercom_message_optout`, `intercom_consent*`, `intercom_held_messages` / mig 0076, 0113, 0114	הגדרות
G	נוכחות באפליקציית הטלפון	צוות שהתקין את האפליקציה	שם/פלטפורמה/דגם/גרסאות המכשיר, אסימון מכשיר מגובב, גרסה וזמן אישור הודעה, נוכחות נוכחית (בפנים/בחוץ, אתר, קו רוחב/אורך אחד עם דיוק), יומן אירועים (כניסה/יציאה/מיקום/חיישן עם קואורדינטות), אסימון דחיפה אטום, קטגוריות מושתקות	`mobile_devices`, `mobile_presence_events`, `mobile_push_messages` / mig 0057	מתג ראשי `presence.*`, ברירת מחדל כבוי (`B/services/presence.py`)
H	תמונות אירועי מצלמה	אנשים שמופיעים בפריים	אחד לאירוע מתוך ההקלטה בשעת האירוע; סוג JPEG אירוע, מזהה מצלמה, זמנים	קבצים ב-`<data>/thumbs/events` / mig 0003	תכונת האירועים
I	התראות	מפעילים	שורות תיבת התראות, יומן מסירה, מנויי דחיפה בדפדפן (נקודת קצה, מפתחות, user agent)	`notifications`, `notification_deliveries`, `push_subscriptions` / mig 0034, 0046	תמיד
J	גיבויים	כל מה שמיוצא	סעיף 4	`<data>/backups/*.zip`	יומי + לפני שדרוג

לא נותח כאן: הקלטות וידאו (נשארות ב-NVR / Frigate ואינן בגיבויי Arx - תיעוד `B/services/backup.py`), מודול החשמל וטלמטריית מכשירים. האם חלות חובות לגבי מצלמות/ מעקב וידאו: **REQUIRES COUNSEL REVIEW (C13)**.

3. גישת טכנאים לדלתות (קטגוריה E) בפירוט

התכונה מאפשרת לספק לדווח ל-Arx אילו טכנאים יגיעו, ולמנהל מורשה לאשר קוד כניסה אישי מוגבל בזמן שמונפק במערכת הכניסה של המבנה ("WisKey"). התכונה **כבויה** (`access.external_grants` ברירת מחדל `off`) ואי אפשר להפעילה בגרסה זו:

`GO_LIVE_PERMITTED = False` ב-`B/services/access_grants.py` גורם למנוע לסרב לכל קריאה ולערוץ הוואטסאפ לא לשלוח דבר. כל מה שלהלן מתאר מה הקוד יעשה אחרי מתן ההיתר.

מה נשמר ב-Arx:

- הספק מקליד שם (עד 60 תווים אחרי נרמול, `B/services/access_arrival.py`) ומספר טלפון. טכנאי שנוסף מדף ההגעה נשמר מיד כשורת מדריך לא פעילה (`ticket_contacts.active = 0`) ושורה ב- `access_pending_contacts` (מזהה ספק, מזהה שיבוץ, יוצר `contact:<id>`, זמן יצירה, זמן אישור/דחייה). כלומר השם והטלפון קיימים ב-Arx לפני שמנהל ראה אותם.
- הטלפון נשמר כספרות וכגיבוב מפתח (`phone_key`) להגבלות קצב; יומן המכסות `access_code_sends` מחזיק את הגיבוב, זמן ותוצאה - לא את המספר ולא את הקוד - ונמחק אחרי יומיים.
- ההרשאה (`access_grants`): הנושא (מזהה `contact`), מקור (ידני / קריאה / הזמנת RFQ), דלתות לפי עמדה, חלון תוקף (עד 14 יום, `MAX_DAYS_CAP`), שעות יומיות אופציונליות, מצב, מי ביקש ואישר ומתי, מצב ומונה שליחת קוד, סיבת סיום. מזהים בלבד: בלי שם, טלפון, קוד או טקסט הודעה.
- אישור ההודעה (`access_grant_notices`): גרסת הנוסח (`n2`), אופן (`page` = הספק סימן, `approver` = המנהל סימן "האדם קיבל הודעה"), מי ומתי. האישור הוא של הספק או המנהל, לא של הטכנאי.
- הקישור לאדם במערכת הכניסה (`access_person_links`): מזהה האדם שם, מקור, מספר עובד ש-Arx יצרה (12 + `x` הקס), מי קישר ומתי.

מה נשלח למערכת הכניסה (`B/services/access_grant_engine.py`, `create_payload`): שם תצוגה (32 תווים ראשונים), מספר עובד אקראי, קטגוריה (קבלן / מבקר), "אחראי" (שם המאשר, עד 64 תווים), מטרה קבועה (עד 128 תווים), תוקף, מפת דלתות ושעות; הקוד האישי בן 6 הספרות נוצר עבור האדם במערכת הכניסה. הטלפון **אינו** נשלח. מערכת הכניסה רושמת כל כניסה לפי שם, שעה ודלת; האם היא שומרת גם תמונה בכניסה ולכמה זמן נקבע בצד מערכת הכניסה ולא אומת: **REQUIRES COUNSEL REVIEW (C7)** (וגם בירור טכני אצל מפעיל מערכת הכניסה).

מה נשלח לטכנאי: הודעת וואטסאפ אחת למספר שהטכנאי אימת (אימות לא ישן מ-`access.external.phone_fresh_days`, ברירת מחדל 180) עם הקוד, שמות הדלתות, תאריכים/שעות ומספר אסמכתא (`TEMPLATES`ב-`B/services/access_grants.py`). ההודעה פותחת בשם המוצר ("SmplWise Arx"), לא בשם הארגון.

מה לא נשמר ב-Arx בשום מקום: הקוד האישי (לא מגובב ולא אורכו), בשום טבלה, יומן או הודעת שגיאה; תעודת זהות, דוא"ל או תמונה של הטכנאי; טקסט הודעה. שורות הביקורת של התכונה נושאות מזהים וספירות (`_audit`ב-`B/services/access_grants.py`).

ההודעה שמוצגת (`NOTICE_TEXT`, גרסה `n2`, he/en/ar/ru): אומרת שנשמרים שם וטלפון, בכל כניסה שעה ודלת (ובמקום שהופעל - תמונה), המטרות, שהמידע נשמר "עד שהארגון מוחק אותו, בהתאם למדיניות השמירה שלו" (לכן קיים `06-retention-policy-template.md`), שאין חובה חוקית למסור את הפרטים אך בלעדיהם לא ניתן להנפיק קוד, ושפונים ל"מנהל המבנה". האם הנוסח מספיק: **REQUIRES COUNSEL REVIEW (C2, C3)**.

4. גיבויים

של "טבלאות הפרויקט" (הגדרות, אתרים/מבנים/קומות, תוכניות, מצלמות, תצוגות שמורות, zip קובץ: `B/services/backup.py` קבוצות, passkeys, משתמשים, פרטי כניסה מקומיים: `ACCESS_TABLES`) הגדרות התראות, מודול החשמל...) וטבלאות הגישה מועברים רק בקטע המוצפן בסיסמת הגיבוי HMAC הרשאות...), ואופציונלית יומן הביקורת והאירועים. גיבובי סיסמאות ומפתחות הערת הקוד מגדירה אותן "נתונים; `PROJECT_TABLES`-של המנהל. טבלאות הקריאות (אנשי קשר, קריאות, הרשאות גישה) **אינן** ב גיבויים ידניים ומועלים אינם נמחקים על ידי הקוד. ;(`KEEP`) "תפעוליים". גיבויים אוטומטיים שנשמרים: 5 "לפני שדרוג" ו-7 "יומיים גיבוי שנלקח לפני מחיקה עדיין מכיל שורות שנמחקו אם היו בהיקף; לגבי קריאות לא נעשה דבר נוסף (תיעוד אחר כך - מחוץ לקוד zip-לאן מועתקים קובצי ה .(`B/services/tickets/deletion.py`: **REQUIRES COUNSEL REVIEW (C8)**.

5. נמענים ושירותים חיצוניים

שירות	מה עובר	ראיה	הערה
וואטסאפ	טלפון הנמען וטקסט ההודעה של קישורי קריאות, קודי אימות, הודעות לאנשים, קודי כניסה לטכנאים	`B/services/messaging_accounts.py`, `B/services/tickets/channel_whatsapp.py`, `send_code` ב-`B/services/access_grants.py`	נשלח דרך אינטגרציית וואטסאפ של Home Assistant (`ha-whatsapp`), פלטפורמה `whatsapp`) מחשבון הוואטסאפ של הארגון; התדריך המשפטי הקיים מתעד אותה כרכיב לא רשמי. Meta מעבדת נתוני מטא. **REQUIRES COUNSEL REVIEW (C5)**
מנהרת Cloudflare	תעבורת הערוץ המרוחק והדפים הציבוריים לספקים/מטפלים (קישורי קריאות, פורטל ספקים, קישורי RFQ, דף ההגעה); ה-TLS מסתיים ב-Cloudflare	`B/remote_channel.py`, `B/config.py`, `B/services/tickets/public_app.py`	שמות/טלפונים שמוקלדים בדפים ציבוריים עוברים דרכה. **REQUIRES COUNSEL REVIEW (C6)**
מערכת הכניסה (WisKey)	רשומת אדם והרשאות (סעיף 3)	`B/services/access_grant_engine.py`	מערכת באתר; השמירה שלה וגישת מתחזק חיצוני אינן נראות כאן. **REQUIRES COUNSEL REVIEW (C7)**
ממסר דחיפה (אפליקציית טלפון)	אסימון ממסר אטום והתראה כללית; הכותרת והגוף האמיתיים נשלפים על ידי האפליקציה מ-Arx עם אסימון המכשיר (תוקף 24 שעות)	הערות mig 0057, `push_relay_url` ב-`B/config.py`, `B/services/mobile_push.py`	מפעיל הממסר ומיקומו אינם מופיעים במאגר. **REQUIRES COUNSEL REVIEW (C9)**
דחיפה בדפדפן	נקודת קצה ומפתחות של שירות הדחיפה של הדפדפן	`B/services/push.py`	מסופק על ידי יצרן הדפדפן
דוא"ל (SMTP)	דוא"ל התראות וקריאות אם הוגדר	`B/services/notify_email.py`, `B/services/tickets/channel_email.py`	כבוי אלא אם הוגדר
Home Assistant	זהות משתמש (Ingress), ישויות/מכשירים/אזורים, ואינטגרציית הוואטסאפ	`docs/security/HA_IDENTITY_RBAC_HE.md`	מנהל המארח יכול להגיע לנתונים מחוץ לבקרת הגישה של Arx (אותו מסמך, סעיף 2)

6. אמצעי אבטחה שקיימים בקוד (עובדות, לא הבטחה)

בקרת גישה לפי תפקידים והרשאות מוגבלות היקף (`B/rbac.py`, `docs/security/HA_IDENTITY_RBAC_HE.md`); כל כתיבה מתועדת; אסימונים וסשנים מגובבים; הגבלות קצב על קודים וקישורים; נוסחי הודעה קבועים בקוד; טלפונים לעולם לא בשורות ביקורת וביומנים (תיעוד `B/services/tickets/contacts.py`); דפים ציבוריים מחזירים 404 אחיד בכל כשל (`docs/security/TICKETS_PUBLIC_SURFACE_REVIEW_CHECKLIST.md`); ביקורת תלויות וסודות ב-`docs/security/DEPENDENCY_AND_SECRETS_AUDIT.md`. האם האמצעים עומדים בתקן אבטחה משפטי כלשהו: **REQUIRES COUNSEL REVIEW (C4)**.